

Tarn

Protocol Specification

Wire format, key hierarchy, storage layout

May 2026

Contents

Tarn Protocol — Working Draft

- App view vs. protocol view
- Key Hierarchy
- Security Model
- App Identity
- Arweave Tag Scheme
- Blob Format
- Credential Mapping on Arweave
- Write Authorization Rules
- API State
- Flows
- Client <-> API Summary
- Design Decisions
- Sharing primitives — terminology
- Muted-connections record (issue #18)
- Session persistence (Section 7, issue #19)
- Server-side session management (Section 7.5, issue #20)
- Invite tokens (Section 8, issue #22)
- Publicly observable metadata
- Cryptographic References
- Open Questions

Tarn Protocol — Working Draft

Status: Active design discussion (Issue #69) **Last updated:** 2026-04-30 (Section 7.5 spec added)

Tarn is an app-agnostic platform for storing encrypted, user-owned data permanently on Arweave. This document defines the complete protocol: identity, authentication, encryption, and data operations.

App view vs. protocol view

This document describes the **wire protocol** — what bytes go on Arweave, what tags identify what, what HTTP shapes the API speaks, what the encryption envelopes look like, how share-log seq mechanics work. Most app developers never need to read it.

The **app-facing SDK** lives in `client/`. It exposes typed CRUD per collection, friend connections, sharing, recovery, and account management — without app code touching tags, txids, encryption envelopes, share-log sequence numbers, or HPKE handshakes.

Read this document when you are:

- **building a new client or server in a different language.** Everything you need to interoperate with Tarn at the wire level is here.
- **debugging a low-level interaction.** When the SDK abstraction frays (it shouldn't, but it sometimes does), the protocol spec is the source of truth.
- **building the "always access your data" recovery client.** The end-game promise of Tarn is that any client with the user's credentials can decrypt their data straight from Arweave with no Tarn API in the loop. That client reads schemas, content blobs, and share logs directly from Arweave gateways via GraphQL. It implements this document.

For ordinary app development, start with the [SDK README](#). Come back here when you actually need wire-level detail.

Key Hierarchy

All sub-keys are derived using **HKDF-Expand** (RFC 5869) with structured info strings. No ad-hoc SHA-256 concatenation. The info string follows a fixed structure:

```
info = protocol || purpose || app_id || version || 0x01
```

Where:

- `protocol` = "tarn" (fixed)
- `purpose` = one of: "lookup", "encrypt", "sign"
- `app_id` = registered app identifier (e.g., "bookish")

- `version = "1"` (derivation version — allows future KDF changes)
- `0x01` = HKDF counter byte per RFC 5869

HKDF-Expand with a single 32-byte output block reduces to one HMAC call:

```
sub_key = HMAC-SHA256(master_key, info)
```

Full derivation chain

email + password (user input, never leaves client)

```
-> master_key      KDF(password, SHA-256(normalizedEmail))
                    v2: Argon2id (m=64MiB, t=3, p=1) – current default
                    v1: PBKDF2-SHA256, 600K iterations – legacy
```

master_key + app_id:

```
-> credential_lookup_key    HMAC-SHA256(master_key, "tarn" || "lookup" || app_id
    || "1" || 0x01)
-> credential_encryption_key HMAC-SHA256(master_key, "tarn" || "encrypt" || app_id
    || "1" || 0x01)
-> signing_key_seed         HMAC-SHA256(master_key, "tarn" || "sign" || app_id
    || "1" || 0x01)
    -> signing_key_pair      ECDSA P-256 from signing_key_seed (see P-256
    derivation)
    -> public_key            sent to API, stored in D1 and on Arweave
    -> private_key           never leaves client
```

Master-key KDF versioning

The KDF version is encoded in the `wrapped_data_key` field of the credential mapping blob (see [Wrapped Data Key](#) below for wire format). New accounts always use Argon2id (v2). Existing PBKDF2 (v1) accounts continue to log in via a legacy path; migration to Argon2id is intentionally out of scope and will be addressed separately.

Login dispatch — because `credential_lookup_key` depends on `master_key` which depends on the KDF, the client cannot know which KDF an account uses before looking it up. The client tries the current default KDF (Argon2id) first; on a 404 it falls back to PBKDF2 with a freshly-derived `credential_lookup_key`. New accounts pay only the Argon2id cost; legacy accounts pay both KDFs once per login (~2s worst case on a representative slow device).

Argon2id parameters were chosen against a ~2s slow-device login budget: 64 MiB memory + 3 iterations + 1-way parallelism (single-threaded; aligns with browser realities). The memory-hard property neutralizes GPU/ASIC parallelism that defeats PBKDF2 — the primary reason for the change.

Per-app isolation: Every derived key includes `app_id`. The same email+password produces completely independent identities per app. Different `credential_lookup_key`, different `encryption_key`, different signing key. A Bookish user and a Cellar user with the same email+password cannot see each other's data, share sessions, or even detect each other's existence.

P-256 private key derivation

The `signing_key_seed` (32 bytes from HMAC) is used as the P-256 private scalar. P-256 requires the private key to be in $[1, n-1]$ where n is the curve order.

```
seed = HMAC-SHA256(master_key, "tarn" || "sign" || app_id || "1" || 0x01)
if seed == 0 or seed >= n:
    seed = HMAC-SHA256(master_key, "tarn" || "sign" || app_id || "1" || 0x02)
    (repeat with incrementing counter – probability of needing this:  $\sim 2^{-128}$ )
```

Import as PKCS#8 DER → export public key as SPKI → send SPKI to API.

Wrapped Data Key

The `data_encryption_key` (DEK) is wrapped using **AES-KW** (RFC 3394, Key Wrap):

```
wrapped_bytes = AES-KW-Wrap(data_encryption_key, credential_encryption_key)
                    ^^^^^ payload          ^^^^^ wrapping key
```

AES-KW is deterministic (no IV), purpose-built for key wrapping, and available in WebCrypto via `crypto.subtle.wrapKey('raw', key, wrappingKey, 'AES-KW')`.

At registration the DEK is generated as 32 fresh random bytes (issue #11) — no more self-wrapping. The DEK is then wrapped under the `credential_encryption_key` and packaged into a v3 envelope (see below).

After a credential change, the wrap is regenerated under the new `credential_encryption_key`. Argon2id accounts also get a fresh DEK appended to the chain at the next-highest generation (forward-secret rotation) — see [Forward-secret DEK rotation](#) below.

Wire format (`wrapped_data_key` field)

The API stores `wrapped_data_key` as opaque text. The string carries a version indicator so the client knows the structure and a KDF indicator so the client can verify which master-key KDF the account was registered under.

v4 (current default — Argon2id accounts after issue #12): JSON envelope with a multi-factor DEK chain. Each chain entry is wrapped under one or more factors; any factor's KEK independently unwraps the DEK. New v4 accounts always carry both `password` and `recovery_phrase` factors.

```
{
  "v": 4,
  "kdf": "argon2id",
  "kdf_params": { "m_kib": 65536, "t": 3, "p": 1 },
  "recovery": {
    "kdf": "argon2id",
    "kdf_params": { "m_kib": 65536, "t": 3, "p": 1 },
    "salt": "<base64 16-byte per-account random salt>"
  },
  "dek_chain": [
    { "gen": 1, "wrappings": [
      { "factor": "password",          "wrapped": "<base64 AES-KW ciphertext (40 bytes)>"
    ]
  },
```

```

    { "factor": "recovery_phrase", "wrapped": "<base64 AES-KW ciphertext (40 bytes)>"
  }
  ],
  { "gen": 2, "wrappings": [
    { "factor": "password", "wrapped": "<base64 AES-KW ciphertext (40 bytes)>"
  }
  ]
}
]
}

```

- `recovery` block is the recovery factor's derivation metadata (Argon2id params + per-account salt). Absent → no recovery factor enrolled (treat as v3-equivalent for read).
- Each `dek_chain` entry's `wrappings` array carries the same DEK wrapped under each factor's KEK. AES-KW is deterministic, so the same (DEK, KEK) pair always produces the same ciphertext bytes — preserving register-retry idempotency.
- When `changeCredentials` runs without the recovery phrase: old gens preserve their existing recovery wrappings verbatim (re-wrapping under the same KEK is byte-identical anyway), and the new gen N+1 has only a `password` wrapping. The gap is closed by `recoverAccount` or `regenerateRecoveryKit`, which re-wrap every gen under the recovery factor.

v3 (legacy single-factor chain — issue #11 accounts pre-issue-#12): JSON envelope with a single-factor DEK chain.

```

{
  "v": 3,
  "kdf": "argon2id",
  "kdf_params": { "m_kib": 65536, "t": 3, "p": 1 },
  "dek_chain": [
    { "gen": 1, "wrapped": "<base64 AES-KW ciphertext (40 bytes)>" },
    { "gen": 2, "wrapped": "<base64 AES-KW ciphertext (40 bytes)>" }
  ]
}

```

The chain is appended only — every credential change adds an entry at gen N+1. The current generation (used for new writes) is the entry with the highest `gen`. Old gens stay in the chain so older content blobs remain decryptable. v3 envelopes are read as a single-factor (`password`) v4 chain with no recovery metadata.

v2 (legacy Argon2id accounts): JSON envelope with a single wrapped DEK.

```

{
  "v": 2,
  "kdf": "argon2id",
  "kdf_params": { "m_kib": 65536, "t": 3, "p": 1 },
  "wrapped": "<base64 AES-KW ciphertext (40 bytes)>"
}

```

v2 accounts upgrade to v3 on next credential change: the existing DEK is preserved as gen 1 (re-wrapped under the new KEK) and a fresh random DEK is minted as gen 2.

v1 (legacy PBKDF2 accounts): the bare base64 AES-KW ciphertext, no envelope. PBKDF2 accounts stay on the legacy single-key path on credential change — issue #11's forward-secret rotation is scoped to Argon2id accounts; v1 → v3 migration is a separate concern.

Detection rule: if `wrapped_data_key[0] === '{'` , parse as JSON and dispatch on `v` ; otherwise treat as v1 bare base64. The base64 alphabet `[A-Za-z0-9+/=]` never starts with `{` , so the prefix check is unambiguous.

All envelope shapes are byte-stable for the same `(email, password, app)` inputs (AES-KW is deterministic; JSON.stringify is insertion-ordered; chain entries are written in generation order). This preserves the register-retry idempotency check (server compares the stored `wrapped_data_key` to the incoming one byte-for-byte; a retry of an interrupted register sends the same bytes).

Forward-secret DEK rotation

On every credential change for an Argon2id account, the client mints a fresh random DEK at gen N+1 and appends it to the chain. Subsequent writes use the new gen; old gens remain in the chain so prior data is still readable. An attacker who later compromises the OLD `credential_encryption_key` cannot decrypt content written after the rotation (the new gen DEK is not derivable from old credentials).

This is the only forward-secrecy property Tarn provides today. Old credential blobs on Arweave remain unwrappable by anyone who held the old credentials, but the DEK they yield is bound to data written before the rotation.

Recovery factor (issue #12)

v4 accounts publish a `recovery_lookup_key` and `recovery_public_key` alongside the password-derived `credential_lookup_key` / `public_key` . Both are derived from the user's BIP39 recovery phrase (24-word, 256-bit entropy) and let the user authenticate to the API for credential rotation when they have lost their password.

Derivation:

```
phrase_entropy      = BIP39 entropy bytes (32 for 24-word phrase)
recovery_lookup_key = HMAC-SHA256(phrase_entropy, "tarn" || "recovery-lookup" ||
  app_id || "1" || 0x01)
recovery_signing_seed = HMAC-SHA256(phrase_entropy, "tarn" || "recovery-sign" ||
  app_id || "1" || 0x01)
recovery_signing_key  = ECDSA P-256 from recovery_signing_seed (same retry rule as
  the password-derived signing seed)
recovery_KEK          = Argon2id(phrase, recovery_salt, m=64MiB, t=3, p=1)
                      (recovery_salt is per-account random, lives in the v4
  envelope's `recovery.salt`)
```

`recovery_lookup_key` and `recovery_signing_key` derive from the raw phrase entropy directly (no salt), so they are stable across credential changes — the phrase remains the same secret regardless of how many times the password rotates. The `recovery_KEK` derives via Argon2id with the per-account salt, providing the slow-brute-force defense at unwrap time.

The recovery phrase is **mandatory at signup** (the SDK enforces this with a synchronous `recoveryAcknowledged: true` flag on `register()`) and is also optionally emailed to the user via the [Recovery email forwarder](#).

Data lookup key

Generated by the API at registration. Random, unique, opaque 64-char hex string. Not derived from any client secret. Returned to the client at registration.

Security Model

Threat model

Tarn assumes credentials are never compromised. Credential changes are a convenience feature (e.g., new email address), not a security remediation tool. All encrypted data is publicly visible on Arweave — security depends entirely on password entropy + PBKDF2 cost.

Forward secrecy on credential change (Argon2id accounts)

Issue #11 added forward-secret DEK rotation for Argon2id accounts. On every credential change a fresh random DEK is appended to the chain at gen N+1; future writes go to gen N+1. An attacker who later compromises old credentials can:

1. Derive the old `credential_lookup_key`
2. Find the old credential mapping blob on Arweave
3. Unwrap the OLD `wrapped_data_key` with the old `credential_encryption_key`
4. Recover DEKs at gens 1..N (the chain entries that existed at the time of the old credential blob)

What they CANNOT do: decrypt content written under gen N+1 (or later). Those CEKs are wrapped under the new DEK, which is not derivable from old credentials. The old credential blob does not contain the new DEK — it predates it.

What's still inherent to immutable storage: the old credential blob itself stays on Arweave forever, so an attacker who compromised the old credentials at any point retains permanent access to data written before the rotation. Tarn cannot revoke past leaks.

Legacy PBKDF2 accounts have no forward secrecy

PBKDF2 (KDF v1) accounts are out of scope for issue #11's rotation. Their DEK is rewrapped under new credentials on every change but never replaced — old credentials still unwrap the same DEK and decrypt all data, past and future.

Password requirements

Since Arweave data is publicly available (encrypted), the security boundary is password entropy + PBKDF2 iteration cost. The API enforces minimum password complexity at registration. 600K PBKDF2 iterations meets OWASP 2023 recommendations.

Per-app isolation

Different apps derive completely independent key sets from the same email+password. A compromise of one app's `credential_lookup_key` reveals nothing about the user's identity in another app. Even Arweave observers cannot link a user's Bookish account to their Cellar account.

What the API knows vs. doesn't know

API sees	API never sees
<code>public_key</code> (for signature verification)	<code>private_key</code> (signing)
<code>credential_lookup_key</code>	<code>master_key</code>
<code>data_lookup_key</code> (it generated it)	email, password
<code>wrapped_data_key</code> (opaque, AES-KW)	<code>data_encryption_key</code>
encrypted data blobs (opaque)	<code>credential_encryption_key</code>
<code>app_id</code> (which app the user registered for)	plaintext of any data blob

No secrets stored by the API. Zero-knowledge preserved for all key material that protects user data.

App Identity

Apps are first-class Tarn entities. An app must be registered before users can create accounts for it.

App registration

Privileged operation (initially manual, eventually a developer portal):

App generates ECDSA P-256 key pair

Tarn operator registers: { `app_id`, `public_key` }

Stored in D1 and on Arweave: Type: 'app-reg', Lk: `app_id`

App authentication

Same challenge-response protocol as users:

```
POST /api/v1/auth/challenge { credential_lookup_key: <app_id> }
```

```
POST /api/v1/auth/verify    { credential_lookup_key: <app_id>, nonce, signature }
```

```
-> JWT with { sub: <app_id>, role: 'app' }
```

App wallets for Arweave storage

Each app has its own Arweave/Turbo wallet (Ethereum-compatible) for signing Dataltems. The wallet private key is stored as a Worker secret (`APP_SIGNING_KEY`). Turbo provides free uploads under 100KB; larger uploads consume the wallet's Turbo balance.

App scoping on user accounts

User accounts are per-app. Registration requires a valid `app` parameter referencing a registered app. The JWT includes `app: <app_id>` . Write endpoints validate that the `App` tag matches `jwt.app` . A user cannot write entries for an app they're not registered with.

Arweave Tag Scheme

All blobs on Arweave carry these tags:

Tag	Meaning	Example
App	App identifier	<code>bookish</code> , <code>winelist</code>
Type	Blob type	<code>cred</code> , <code>entry</code> , <code>acct</code>
Lk	Lookup key (64-char hex)	<code>a3f8...</code>
Enc	Encryption method	<code>aes-256-gcm</code> or <code>tarn-cek-1</code>
V	Protocol version	<code>0.4.0</code>

For credential blobs: `Lk` = `credential_lookup_key` . For data blobs: `Lk` = `data_lookup_key` .

Additional tags for versioning and key rotation (data blobs only):

Tag	Meaning
Prev	Txid of prior version (edits)
Op	Operation flag (<code>tombstone</code>)
Ref	Txid referenced by tombstone
Gen	DEK generation that wrapped the per-content CEK (issue #11)

The `Gen` tag is present on new-format (`Enc: tarn-cek-1`) blobs; it carries the integer generation number (e.g. `1` , `2`) that selects which DEK from the user's chain unwraps the blob's CEK. Legacy `aes-256-gcm` blobs carry no `Gen` tag and decrypt with the gen-1 DEK directly.

Blob Format

Two formats coexist; the SDK detects which by inspecting the first 5 bytes.

New format — per-content CEK (issue #11, default for v3 accounts)

[magic: 5 bytes][wrapped_CEK: 40 bytes][IV: 12 bytes][ciphertext + GCM tag: N+16 bytes]

- magic = 0x54 0x41 0x52 0x4e 0x02 — ASCII "TARN" followed by version byte 0x02 . The trailing byte is the format version; future revisions reuse the 0x54 0x41 0x52 0x4e prefix and increment.
- CEK is generated fresh per blob (`crypto.getRandomValues(32)`). wrapped_CEK = AES-KW(CEK, DEK[currentGen]) — 40 bytes (32-byte CEK + 8-byte AES-KW overhead).
- IV is 12 random bytes per encryption.
- Ciphertext is AES-256-GCM with the per-blob CEK over UTF-8-JSON plaintext.

Per-blob fixed overhead: 73 bytes (5 + 40 + 12 + 16).

The generation indicator does not live in the blob bytes — it travels alongside as the Arweave Gen tag (e.g. Gen: 1 , Gen: 2). This keeps the byte layout stable so a recipient who only has the CEK (sharing protocol, future Section 5 work) can skip bytes 5..44 and decrypt bytes 45..end without parsing tags.

Reading. The owner reads bytes 5..44 (wrapped_CEK), unwraps it with DEK[gen] (gen from the Gen tag, default 1 if absent), and decrypts bytes 45..end with that CEK. A recipient with a CEK from a share log skips the wrapped portion and decrypts directly.

The Enc tag for new-format blobs is tarn-cek-1 .

Legacy format

[IV: 12 bytes] [ciphertext + GCM tag: N bytes]

Direct AES-256-GCM with the user's DEK. No magic prefix. Enc: aes-256-gcm . Pre-issue-#11 blobs and writes by accounts that haven't yet upgraded to v3 envelopes.

Detection. SDK reads the first 5 bytes. Match against 0x54 0x41 0x52 0x4e 0x02 → new format; otherwise legacy. Legacy blobs continue to decrypt indefinitely — no migration is performed.

Credential Mapping on Arweave

The credential mapping blob is **not encrypted**. It contains:

```
{
  "data_lookup_key": "<64-char hex>",
  "wrapped_data_key": "<base64-encoded AES-KW ciphertext or v3/v4 envelope JSON>",
```

```

    "public_key": "<base64-encoded ECDSA P-256 SPKI public key>",
    "app": "<app_id>",
    "recovery_lookup_key": "<64-char hex>",
    "recovery_public_key": "<base64-encoded ECDSA P-256 SPKI public key>"
  }

```

The `recovery_lookup_key` and `recovery_public_key` fields (issue #12) are written when the account has a recovery factor enrolled and omitted otherwise (pre-v4 accounts). On rebuild from Arweave, missing fields decode as NULL.

No value here is secret. Storing unencrypted enables:

- Single API call for registration (no second client round-trip)
- Full API self-healing from Arweave (all account fields recoverable)
- No asymmetric crypto complexity for negligible privacy gain

Write Authorization Rules

Write access is controlled by a **rules** array on each user account. At write time, the API evaluates all rules — **every rule must pass**. Unknown rule types **fail closed** (deny).

Rules are set by authenticated app identities. The entire rules array is **replaced** on each update (no merging).

Rule types (v1)

`max_entries` — user has fewer than N entries matching the filters

```

{ "type": "max_entries", "limit": 1000, "since": "2026-04-01T00:00:00Z", "app":
  "bookish", "entry_type": "entry" }

```

`max_bytes` — this individual entry is smaller than N bytes

```

{ "type": "max_bytes", "limit": 102400 }

```

`expires` — the current time is before this timestamp

```

{ "type": "expires", "at": "2027-04-01T00:00:00Z" }

```

Rule evaluation

For each rule: unknown type -> DENY; evaluates false -> DENY

All rules pass -> ALLOW

No rules (NULL) -> DENY (accounts require rules to be set by the app)

Note: with per-app accounts, the default for new accounts is DENY (no rules set). The app must set rules after the user registers. For free-tier apps, set `[{ "type": "max_entries", "limit": 5 }]` immediately after user creation.

API State

D1 `accounts` table:

```
credential_lookup_key TEXT PRIMARY KEY,  
public_key TEXT NOT NULL,  
data_lookup_key TEXT NOT NULL UNIQUE,  
wrapped_data_key TEXT NOT NULL,  
app TEXT NOT NULL,  
rules_json TEXT,  
created_at INTEGER NOT NULL,  
recovery_lookup_key TEXT,      -- nullable; UNIQUE when present (issue #12)  
recovery_public_key TEXT      -- nullable (issue #12)
```

D1 `apps` table:

```
app_id TEXT PRIMARY KEY,  
public_key TEXT NOT NULL,  
created_at INTEGER NOT NULL
```

D1 `entries` table (authoritative store for live state; see "D1 authority" below):

```
txid TEXT PRIMARY KEY,  
app TEXT, type TEXT,  
lookup_key TEXT,  
prev_txid TEXT, is_tombstone INTEGER, tombstone_ref TEXT,  
block_timestamp INTEGER, tags_json TEXT, cached_at INTEGER
```

D1 authority

Tarn is the sole write path for any data associated with a (`data_lookup_key` , `app` , `type`) tuple. Every successful write synchronously upserts into D1 before returning success to the client. As a consequence:

- **D1 is authoritative for live state.** Once a tuple has been bootstrapped, reads are served entirely from D1. Tarn does not periodically re-scan Arweave — there is no other writer to reconcile against.
- **Bootstrap markers** (stored in `cache_meta`) record that a tuple has been ingested. Set by the write path on first write, or by the read path on first read if no marker exists.
- **Arweave GraphQL is consulted only on cold bootstrap:** a first read for a tuple Tarn has never processed. After bootstrap, the marker short-circuits all subsequent queries.
- `block_timestamp` / **confirmation status** is set at write time (NULL = pending) and no longer updates once the marker is set. Clients that need Arweave confirmation status can check Turbo directly for a given txid.

Rebuild from Arweave: All tables fully rebuildable from Arweave blob scans. After rebuild, `cache_meta` markers are cleared so the next read for each tuple re-bootstraps from the restored `entries` rows.

Flows

1. Register (new account)

CLIENT (local):

1. Derive master_key from email + password (Argon2id v2; PBKDF2 v1 legacy only)
2. Derive credential_lookup_key, credential_encryption_key, signing_key_pair
(all include app_id in HKDF info)
3. data_encryption_key (DEK) = crypto.getRandomValues(32) // issue #11
4. wrapped_data_key = v3 envelope:
 { v: 3, kdf, kdf_params,
 dek_chain: [{ gen: 1, wrapped: AES-KW-Wrap(DEK, credential_encryption_key) }] }

CLIENT -> API:

5. POST /api/v1/auth/register
 Body: { credential_lookup_key, public_key, wrapped_data_key, app }

API:

6. Verify app is registered in apps table (-> 400 if not)
7. Check credential_lookup_key not already in use (-> 409 if exists)
8. Generate data_lookup_key (random, unique)
9. Store in D1: { credential_lookup_key, public_key, data_lookup_key, wrapped_data_key, app }
10. Persist credential mapping to Arweave
11. Return: { data_lookup_key }

2. Sign in (existing account, any device)

CLIENT (local):

1. Derive master_key, credential_lookup_key, credential_encryption_key, signing_key_pair
(all include app_id in HKDF info)

CLIENT -> API:

2. POST /api/v1/auth/challenge { credential_lookup_key }
 Returns: { nonce, data_lookup_key, wrapped_data_key }

CLIENT (local):

3. Sign nonce with private_key -> signature
4. data_encryption_key = AES-KW-Unwrap(wrapped_data_key, credential_encryption_key)

CLIENT -> API:

5. POST /api/v1/auth/verify { credential_lookup_key, nonce, signature }
 Returns: { jwt }
 JWT contains: { sub: data_lookup_key, role: 'user', app: app_id }

3. Create data

CLIENT -> API:

```
POST /api/v1/entries [JWT]
Tags: { App, Type, Lk: data_lookup_key, Enc, V }
Body: encrypted_blob
```

API:

1. Verify JWT
2. Check App tag matches jwt.app
3. Check Lk tag matches jwt.sub (data_lookup_key)
4. Evaluate write authorization rules -> 403 if denied
5. Build + sign DataItem, cache in D1, upload to Turbo in background
6. Return: { txid, status: 'pending' }

4. Retrieve data

```
GET /api/v1/entries?app={app}&type={type}&key={data_lookup_key}
No auth required. IP rate-limited.
Returns resolved entries (tombstones applied, Prev-chains resolved).
Client downloads + decrypts blobs from Arweave gateways.
```

5. Update data

```
PUT /api/v1/entries/{prior_txid} [JWT]
Tags include Prev: prior_txid. API verifies ownership. Old entry superseded.
```

6. Delete data

```
DELETE /api/v1/entries/{target_txid} [JWT]
Tags include Op: tombstone, Ref: target_txid. Entry hidden by resolution.
```

7. Change credentials

CLIENT (authenticated with old credentials, holds DEK chain DEK[1..N]):

1. Derive NEW keys from new email + password (same app_id, same KDF version)
2. Argon2id (v3 envelope) accounts – forward-secret rotation:
 - Mint DEK[N+1] = crypto.getRandomValues(32)
 - new_wrapped_data_key = v3 envelope with chain entries:
[{ gen: i, wrapped: AES-KW(DEK[i], new_credential_encryption_key) }
for i in 1..N+1]
 - Future writes use Gen=N+1
3. PBKDF2 (v1 legacy) accounts – single-key rewrap, no rotation:
 - new_wrapped_data_key = bare base64 AES-KW(DEK[1],
new_credential_encryption_key)

CLIENT -> API:

```
PUT /api/v1/auth [JWT from old credentials]
Body: { new_credential_lookup_key, new_public_key, new_wrapped_data_key }
```

data_lookup_key unchanged. Existing data untouched. Old gens stay readable;
new writes go to the new gen.

7a. Account recovery (via recovery phrase) — issue #12

When the user has lost their password (or wants a security-grade reset, per the design-doc positioning of recovery as the response to suspected compromise):

CLIENT (local – only the recovery phrase + new credentials):

1. phrase_entropy = BIP39.mnemonicToEntropy(phrase)
2. recovery_lookup_key = HMAC(phrase_entropy, "tarn" || "recovery-lookup" || app_id || "1" || 0x01)
3. recovery_signing_key = ECDSA P-256 from HMAC(phrase_entropy, "tarn" || "recovery-sign" || app_id || "1" || 0x01)

CLIENT -> API:

4. POST /api/v1/auth/challenge { recovery_lookup_key }
Returns: { nonce, data_lookup_key, wrapped_data_key } (the existing v4 envelope)

CLIENT (local):

5. Parse v4 envelope → recovery_salt + KDF params
6. recovery_KEK = Argon2id(phrase, recovery_salt, params)
7. Unwrap DEK chain via FACTOR_RECOVERY_PHRASE
8. Sign nonce with recovery_signing_key.privateKey

CLIENT -> API:

9. POST /api/v1/auth/verify { recovery_lookup_key, nonce, signature }
Returns: { jwt } (JWT carries via_recovery: true)

CLIENT (local):

10. Derive new password keys from (newEmail, newPassword)
11. Re-wrap entire DEK chain under {new_password_KEK, recovery_KEK} factors
(preserving the existing recovery salt; recovery wrappings are byte-identical to the originals by AES-KW determinism)
12. Build v4 envelope from re-wrapped chain

CLIENT -> API:

13. PUT /api/v1/auth { new_credential_lookup_key, new_public_key,
new_wrapped_data_key,
new_recovery_lookup_key,
new_recovery_public_key }
(recovery_lookup_key + recovery_public_key are unchanged by recovery – phrase is the same;
we re-send them so a corrupted server-side row would self-heal.)

data_lookup_key unchanged. All pre-recovery data is decryptable under the new credentials.

8. D1 Recovery

All tables fully rebuildable from Arweave. Entries self-heal on cache miss. Accounts rebuilt from `Type=cred` blobs. Apps rebuilt from `Type=app-reg` blobs.

9. Delete account

DELETE /api/v1/auth [JWT]

Tombstones credential mapping on Arweave. Deletes D1 account row.
Data remains encrypted on Arweave permanently.

10. Set user write rules (app -> API)

PUT /api/v1/accounts/{data_lookup_key}/rules [JWT with role: 'app']
Body: { rules: [...] }
Replaces rules_json. Persists to Arweave as Type: 'app-config'.

Client <-> API Summary

Auth endpoints

POST /api/v1/auth/register

Body: { credential_lookup_key, public_key, wrapped_data_key, app }
Auth: none
Returns: { data_lookup_key }
Errors: 400 (unregistered app), 409 (credential_lookup_key in use)

POST /api/v1/auth/challenge

Body: { credential_lookup_key }
OR { recovery_lookup_key } (issue #12 – recovery flow)
Auth: none
Returns: { nonce, data_lookup_key, wrapped_data_key }
Errors: 404 (unknown lookup key)

POST /api/v1/auth/verify

Body: { credential_lookup_key, nonce, signature }
OR { recovery_lookup_key, nonce, signature } (issue #12 – recovery flow)
Auth: none (signature IS the auth – verified against the public key matching the lookup key type)
Returns: { jwt } (JWT carries via_recovery: true when the recovery_lookup_key path is used)
Errors: 401 (invalid/expired nonce, bad signature)

PUT /api/v1/auth

Body: { new_credential_lookup_key, new_public_key, new_wrapped_data_key,
new_recovery_lookup_key?, new_recovery_public_key? } (recovery fields optional, issue #12)
Auth: JWT (works with both regular login JWTs and via_recovery: true JWTs)
Returns: 200 OK
Errors: 401, 409 (new credential_lookup_key OR new_recovery_lookup_key already in use)

DELETE /api/v1/auth

Auth: JWT
Returns: 200 OK
Errors: 401

POST /api/v1/recovery/email

issue #12

Body: { recipient_email, pdf_base64, app_name?, subject? }
Auth: JWT (user)
Returns: { ok: true }
Errors: 400 (validation), 401, 413 (PDF too large), 429 (5/hour/account),
502 (relay rejected), 503 (relay not configured)

Recovery email forwarder (issue #12)

`POST /api/v1/recovery/email` forwards a client-rendered recovery PDF (containing the user's BIP39 phrase) to the named recipient via the configured email relay (Resend by default).

No-storage guarantee, brief in-memory visibility. The Tarn API holds the PDF bytes in memory only for the duration of the relay request and discards them on response. No D1 row, no KV entry, no Arweave write. The honest framing is "no storage, brief in-memory visibility during the forward" — Tarn briefly sees the bytes because forwarding requires it; persistence does not happen.

Configuration. Two Cloudflare Worker secrets must be set on the API:

```
EMAIL_FORWARDER_API_KEY    # Resend API key (re...)
EMAIL_FORWARDER_FROM        # Verified sender, e.g. "Tarn <recovery@tarn.dev>"
```

If either is missing the endpoint returns 503 with `{error: "Email forwarder not configured"}`. Apps can opt out of email delivery at registration (`emailRecoveryKit: false`) and let the user save the PDF locally instead.

Rate limit. 5 sends/hour per `data_lookup_key`, enforced via the `write_rate_limits` D1 table with the key prefix `recovery-email:`.

App endpoints

```
PUT /api/v1/accounts/{data_lookup_key}/rules
  Body: { rules: [...] }
  Auth: JWT with role: 'app'
  Returns: 200 OK
  Errors: 401, 403
```

```
GET /api/v1/status
  Auth: JWT (user or app)
  Returns: { users, entries, apps, wallet, protocol_version, timestamp }
```

Data endpoints

POST /api/v1/entries

Headers: Authorization: Bearer <jwt>, X-Arweave-Tags: [...]

Body: <encrypted blob bytes>

Auth: JWT

Returns: { txid, status: 'pending' }

Errors: 401, 403 (Lk/App mismatch or rules deny), 413

POST /api/v1/entries/batch

Body: { entries: [{ data: "<base64 encrypted bytes>", tags: [...] }, ...] }

Auth: JWT

Returns: { entries: [{ txid, gateway }], count, status: 'pending' }

Errors: 401, 403, 413

Max 100 entries per batch. Counts as 1 rate-limit hit.

Rules evaluated once for the entire batch (max_entries checks count + batchSize).

GET /api/v1/entries?app={app}&type={type}&key={data_lookup_key}

Auth: none (IP rate-limited)

Returns: { entries: [{ txid, tags }], total }

PUT /api/v1/entries/{prior_txid}

Auth: JWT

Returns: { txid, prevTxid, status: 'pending' }

DELETE /api/v1/entries/{target_txid}

Auth: JWT

Returns: { txid, tombstoneRef, status: 'pending' }

Design Decisions

Why HKDF-Expand (HMAC) for sub-key derivation

Raw `SHA-256(key || domain)` is vulnerable to length-extension attacks. HMAC (which is HKDF-Expand for a single output block, per RFC 5869) is immune by construction. The structured info string `protocol || purpose || app_id || version || counter` replaces ad-hoc domain strings with a defined, versioned format that naturally accommodates per-app isolation.

Why AES-KW for key wrapping

AES-KW (RFC 3394) is purpose-built for key wrapping: deterministic (no IV management), minimal overhead (8 bytes), built-in integrity checking, and available in WebCrypto natively via `wrapKey / unwrapKey`. AES-GCM works but is not the specialist tool.

Why per-app account isolation

Same email+password produces independent identities per app via the `app_id` in the HKDF info string. This prevents cross-app data leakage, cross-app session sharing, and cross-app identity correlation on Arweave. It also means apps must be registered before users can create accounts, which closes the "anyone can freeloader on Tarn's Arweave wallet" gap.

Why app validation at registration

Write endpoints check `App` tag against `jwt.app`. The JWT's `app` claim is set at login based on the account's registered app. Unregistered apps cannot create accounts, therefore cannot get JWTs, therefore cannot write data. This is enforced at the identity layer, not the write layer.

Why default rules are DENY

New accounts have `rules_json = NULL`, which means DENY. The app must explicitly set rules after user creation (e.g., free tier: `max_entries=5`). This prevents orphaned accounts from writing unlimited data on the app's Arweave wallet.

Why reads are unauthenticated

Data is on Arweave permanently (encrypted). Auth on reads only protects the cache layer. A permanent, auditable, API-independent data export page must be possible.

Why a fresh random DEK at registration (issue #11)

Earlier versions of Tarn self-wrapped the `credential_encryption_key` as the DEK at registration, redundantly but uniformly. Issue #11 replaced this with a fresh `crypto.getRandomValues(32)` DEK at gen 1. This is a prerequisite for forward-secret DEK rotation (different gens must be independent random keys, not derived from credentials) and for the planned recovery-phrase factor (different KDFs must be able to wrap the *same* DEK independently).

Why per-content CEKs (issue #11)

Each blob is encrypted with its own freshly-generated 32-byte CEK; the CEK is wrapped under the current generation's DEK and prepended to the blob. This adds 73 bytes per blob but enables granular access control for the future sharing protocol (a CEK can be shared to another user without exposing the DEK), per-content rotation on revocation, and simpler capability delegation. The 5-byte magic prefix `0x54 0x41 0x52 0x4e 0x02` makes the format unambiguously distinguishable from legacy direct-DEK blobs.

Why the generation tag lives in Arweave tags, not in the blob

Section 5 (sharing protocol) requires that a recipient holding only a CEK can decrypt the content portion of a blob without knowing or parsing the owner-side wrapped CEK header. Encoding the generation in the blob bytes would shift the content offset and break that invariant. Putting the generation in an Arweave `Gen` tag keeps bytes 5..44 reserved for the wrapped CEK and bytes 45..end as CEK-only-decryptable content — independent of who's reading.

Sharing primitives — terminology

The full sharing protocol (HPKE handshake, per-pair stealth-addressed share log, identity rotation, revocation) is specified in [notes/2026-04-28-tarn-sharing-design.md](#). Section 6 of the implementation plan (issue #18) renamed the public surface from "friend" to "connection" so the SDK is product-neutral. The on-the-wire protocol identifiers are now:

Layer	Identifier
HPKE info (request)	tarn-connection-request-v1
HPKE info (accept)	tarn-connection-accept-v1
Inbox tag prefix	tarn-connection-inbox-v1-
Connections record content_id	tarn-connections-v1
Pending requests record content_id	tarn-pending-requests-v1
Server-recognized inbox blob types	connection-request-v1 , connection-accept-v1

The persisted connections record's inner array field is `connections: [...]` (was `friends: [...]` in the design doc).

Muted-connections record (issue #18)

The mutual-connection primitive is symmetric — both sides see each other's share-log entries by default. Apps that want a Strava-style asymmetric "follow" feel build it on top of the mutual primitive plus a per-side mute filter. The SDK persists the filter as an encrypted Tarn data blob:

```
content_id = "tarn-muted-connections-v1"
plaintext = JSON({
  app_id: <string>,
  version: 1,
  muted:  [{ share_pub: B(32 bytes), muted_at: <unix_seconds> }, ...]
})
```

DEK-encrypted via the per-content CEK pattern (same as the connections + pending-requests records). Stored on Arweave as a normal `tarn-share-state` entry with `Eid=tarn-muted-connections-v1`, so it syncs across the user's own devices via the existing data-blob storage path. No new D1 schema, no API change.

Semantics — explicitly local:

- **Per-side, per-user.** Mute is set by the muting party only. The muted party receives no signal and continues publishing share-log entries to the muting party's outbound log as normal. Only the muting party's *view* changes.
- **No protocol-level effect.** Mute does NOT alter what the muted party can see, what they can publish, or what tags either side polls. It is purely a UI hint.
- **App-driven filtering.** `readShareLog` and `syncShareLog` do NOT short-circuit on muted connections. Apps still need programmatic access to muted-connection state (e.g., to render a "Muted" tab). The SDK exposes `isMuted(connection)` and `listMutedConnections()` so apps can filter at the call sites that should be filtered (the main feed) without losing access at the call sites that shouldn't (the muted tab).

```
SDK surface:    tarn.muteConnection(c) /    tarn.unmuteConnection(c) /  
    tarn.listMutedConnections() /    tarn.isMuted(c) .
```

Session persistence (Section 7, issue #19)

A logged-in `TarnClient` holds a bag of derived secrets in memory: the password-derived signing keypair, the unwrapped DEK chain, the X25519 sharing keypair, and the JWT. When the page closes, this state is lost — the user must re-enter their password (paying the full Argon2id cost) on every tab open and every browser restart.

For consumer apps this is a UX floor that's hard to ship below. Section 7 adds an explicit, opt-in session-persistence primitive that lets apps trade a bounded increase in attack surface for the ability to restore the in-memory state without re-deriving from password.

Why it must be opt-in

Persisting derived keys to client-side storage is a meaningful change to Tarn's threat surface. Today, a same-origin XSS on a Tarn app can act as the user **for as long as the page is open** — once the tab closes, the keys are gone. With persistence enabled, the same XSS gains the ability to either decrypt the persisted blob in-page (calling the SDK on the live origin) or, if combined with a localStorage/IndexedDB exfil to a remote server, replay the session **only while the wrapping key remains valid** (see at-rest encryption below).

This is a real escalation, even with a non-extractable wrapping key. Apps with stricter postures should not opt in. The default (`new TarnClient(api, appId)` followed by `login()`) does not persist anything; apps must explicitly call `serializeSession()` to enable persistence.

Threat model

What persistence costs:

1. **Same-origin XSS becomes pseudo-persistent.** An attacker who lands code execution on the origin can call `resumeSession()` on the persisted blob and act as the user up to the blob's `expiresAt`. This is bounded by the 7-day max age and by the absence of refresh-on-use (see lifecycle).
2. **No server-side revocation in v1.** A user who suspects their device is compromised cannot tell the API "log out all sessions." The mitigation is `changeCredentials()` — which rotates the signing key and the DEK chain, and the SDK clears the IndexedDB wrapping key as a side effect, rendering all previously-emitted blobs on this origin unreadable. v2 will add per-session identifiers and an explicit revoke endpoint so a user can invalidate sessions without changing credentials.
3. **Cross-tab attack visibility.** All same-origin tabs can read each other's IndexedDB and localStorage. An attacker on one tab can resume the session on another. This is identical to the existing same-origin XSS surface and is not new.

What persistence does NOT cost:

1. **Cross-origin attackers** see no change. The wrapping key is bound to origin via IndexedDB scoping; the persisted blob is unreadable off-origin.
2. **Network attackers** see no change. The persisted blob never leaves the device.
3. **Tarn API operators** see no change. The persisted blob is never sent to the API.

Wire format (pre-encryption JSON)

The plaintext payload below is what gets encrypted under the at-rest wrapping key. Apps **MUST** treat the resulting ciphertext as opaque — schema fields are subject to change in future versions and are documented here only so the threat model can be reasoned about.

```
{
  "v": 1,
  "createdAt": "<unix-seconds>",
  "expiresAt": "<unix-seconds>",
  "apiBase": "https://api.tarn.dev",
  "appId": "bookish",
  "email": "user@example.com",
  "dataLookupKey": "<64-char hex>",
  "credentialLookupKey": "<64-char hex>",
  "kdfVersion": 2,
  "envelopeVersion": 4,
  "currentGen": 2,
  "dekByGen": [
    { "gen": 1, "rawBytes": "<base64 32 bytes>" },
    { "gen": 2, "rawBytes": "<base64 32 bytes>" }
  ],
  "signingPrivateKey": "<base64 PKCS#8 DER>",
  "signingPublicKey": "<base64 SPKI>",
  "sharingPrivateKey": "<base64 32 bytes>",
  "sharingPublicKey": "<base64 32 bytes>",
  "recoveryFactorMeta": null | {
    "salt": "<base64 16 bytes>",
    "kdfParams": { "m_kib": ..., "t": ..., "p": ... },
    "wrappingsByGen": [{ "gen": 1, "wrapped": "<base64>" }, ...]
  },
  "jwt": "<jwt or null>"
}
```

The `credential_encryption_key` is intentionally NOT persisted — once the DEK chain is unwrapped at login, the KEK becomes dead state on the client (no code path reads it post-login). Re-deriving it would require the password, which we do not have. Persistence carries the unwrapped DEKs directly, sidestepping the KEK entirely. The recovery factor's `wrappingsByGen` is preserved verbatim (per-gen AES-KW ciphertext bytes) so a subsequent `changeCredentials()` can re-emit the recovery wrappings without requiring the user to re-enter the phrase, matching the in-memory `#recoveryFactorMeta` semantics.

At-rest encryption

The plaintext schema above is encrypted under an AES-256-GCM wrapping key managed by the SDK and stored in IndexedDB (database `tarn-session`, object store `keys`, record id `wrapping-key-v1`). The wrapping key is created with `extractable: false` so its raw bytes never enter JS userland — even if XSS reads the IndexedDB store, it can only invoke the key for decrypt (which still grants in-page session takeover) but cannot exfiltrate it for offline replay on another device or origin.

on-disk blob (returned from `serializeSession`, base64url-encoded):
IV (12 bytes) || AES-256-GCM ciphertext+tag

wrapping key (in IndexedDB, non-extractable):
AES-256-GCM, generated on first persist, scoped to origin

The SDK creates the wrapping key on first call to `serializeSession()`. Subsequent calls reuse it. `clearSession()` deletes the IndexedDB record, which renders all previously-emitted blobs on this origin unreadable.

Lifecycle

1. **Creation.** App authenticates via `login()`, `register()`, or `recoverAccount()`. App calls `await client.serializeSession()` and stores the returned blob (typically in `localStorage`).
2. **Resume.** On a subsequent page load, app calls `await TarnClient.resumeSession(apiBase, appId, blob)`. If the blob is well-formed, decryptable on this origin, schema-version `1`, and not past `expiresAt`, returns a logged-in `TarnClient`. Otherwise returns `null` — caller falls back to the login UI.
3. **Expiry.** Hard 7-day max age, baked into the blob's `expiresAt` field at creation. The SDK does NOT auto-refresh expiry on use — a "fresh" blob is only emitted by an explicit `serializeSession()` call. This bounds the worst-case window of a quiet exfil-and-replay attack.
4. **Invalidation events.** `changeCredentials()`, `recoverAccount()`, and `deleteAccount()` all rotate the signing key and the DEK chain. The SDK clears the IndexedDB wrapping key on each, rendering all previously-emitted blobs on this origin unreadable. Apps that want continued persistence must re-call `serializeSession()` after these events.
5. **Explicit logout.** `await client.clearSession()` deletes the IndexedDB wrapping key. Subsequent `resumeSession()` calls return `null` for any pre-existing blob.

The `expiresAt` field is enforced client-side. A motivated attacker with code execution on the origin could in principle tamper with the field before it's encrypted (the SDK is in their JS context; they can call any of its functions). v1 accepts this — the threat is upper-bounded by the existing in-page-XSS exposure, which is itself the dominant risk this section is documenting.

SDK API surface

`client.serializeSession(): Promise<string>`

Requires: client is authenticated.

Returns: opaque base64url ciphertext.

Side effects: creates the IndexedDB wrapping key if absent; idempotent.

Throws: if the client is not authenticated.

`TarnClient.resumeSession(apiBase, appId, blob): Promise<TarnClient | null>`

Returns: a logged-in TarnClient, or null if the blob is expired, tampered, schema-mismatched, or unreadable on this origin.

Never throws on bad blobs – null is the recoverable signal so apps can uniformly fall back to the login UI without distinguishing failure modes.

`client.clearSession(): Promise<void>`

Deletes the IndexedDB wrapping key. Renders all previously-emitted blobs unreadable on this origin. Does not affect the in-memory client state – the caller can keep using the live client until it's garbage-collected.

Known v1 gaps

- **No server-side revocation.** Addressed in [Section 7.5](#) below — per-session identifiers + revoke endpoints. Until 7.5 ships, "log out all devices" requires `changeCredentials()`.
- **No idle expiry.** Blobs expire only at the hard 7-day mark; an actively-used session has no separate idle timeout. Apps that want shorter idle windows can implement them by calling `clearSession()` from their own activity tracker.
- **Browser-only.** The IndexedDB + non-extractable WebCrypto storage strategy is browser-specific. Tarn-on-Node and Tarn-on-React-Native session persistence are deferred — the API surface (`serializeSession` / `resumeSession`) is intentionally storage-agnostic in shape so a future implementation can swap backends without changing the surface.
- **No share-log cache participation.** Persisted sessions hydrate share-log state on first read/sync from Arweave, just like fresh logins. Pure perf optimization, not a correctness gap.

Server-side session management (Section 7.5, issue #20)

Section 7 covers persistence on a single device — keeping a logged-in client alive across page reloads. Section 7.5 covers the complementary capability across devices: letting users see active sessions and revoke individual ones without performing a full credential change.

The combination closes the consumer-app session story. Apps render a "Manage devices" page; users kill an unwanted session with a click; the API enforces the revocation immediately.

Why server-side state at all

Today, JWTs are stateless: signed at `/auth/verify`, verified by signature + expiry on every authenticated request, with no D1 round-trip. This is the right default for performance and operational simplicity. The cost: there is no way to invalidate a JWT before its 15-minute TTL elapses.

Section 7.5 makes user-role JWTs stateful by attaching a per-session identifier (`sid`) and a corresponding row in a new D1 `sessions` table. Revoking a session = deleting the row. Subsequent authenticated requests carrying that JWT fail at the middleware layer.

App-role JWTs (`role: 'app'`) stay stateless. Apps are not session-tracked in v1 — per-app revocation is a separate concern handled at the app-registry level.

D1 schema

New migration `0013_sessions.sql` :

```
CREATE TABLE IF NOT EXISTS sessions (  
  sid TEXT PRIMARY KEY,  
  data_lookup_key TEXT NOT NULL,  
  app TEXT NOT NULL,  
  created_at INTEGER NOT NULL,  
  last_seen_at INTEGER NOT NULL,  
  device_label TEXT,  
  via_recovery INTEGER NOT NULL DEFAULT 0  
);  
CREATE INDEX IF NOT EXISTS idx_sessions_dlk ON sessions(data_lookup_key);  
CREATE INDEX IF NOT EXISTS idx_sessions_last_seen ON sessions(last_seen_at);
```

`sid` is a UUID (v4). `device_label` is nullable and app-supplied at `/auth/verify` time (see below). `via_recovery` mirrors the JWT's `via_recovery` claim so the user can see in their session list whether a session was created via the recovery flow.

JWT changes

User-role JWTs gain a `sid` claim:

```
{ "sub": "<data_lookup_key>", "role": "user", "app": "<app_id>", "sid": "<uuid>",  
  "iat": ..., "exp": ... }
```

App-role JWTs unchanged. `via_recovery: true` JWTs (issue #12) also carry `sid` .

`/auth/verify` body changes

```
POST /api/v1/auth/verify  
Body: {  
  credential_lookup_key | recovery_lookup_key,  
  nonce,  
  signature,  
  previous_sid?: string,           // optional – see "session continuity" below  
  device_label?: string,           // optional – max 64 chars; stored on new sessions only  
}
```

Session continuity across JWT refreshes

The SDK's `#requireAuth` silently re-authenticates when the JWT expires. Without continuity, every refresh would create a new session row — ~96 rows/day per active device under typical use.

To prevent that, `/auth/verify` accepts an optional `previous_sid` :

- **Present and active for the same** `data_lookup_key` : server reuses the sid, updates `last_seen_at` , returns a fresh JWT with the same `sid` . No new row.
- **Absent, expired, or revoked:** server mints a new sid, inserts a new row. Returns the new sid in the JWT.

The SDK extracts `sid` from its current JWT (decoding the payload, no signature check needed since the SDK trusts its own state) and passes it as `previous_sid` on every re-verify. Result: one row per device-installation per app, persisting until either the user revokes it or the lazy-prune step (next paragraph) removes it as stale.

Lazy pruning

At the start of `/auth/verify` , before minting a new sid, the server runs:

```
DELETE FROM sessions
WHERE data_lookup_key = ?1 AND last_seen_at < ?2
```

with `?2 = now - 24h` . This bounds the table to "sessions used in the last 24h" per account. A user who hasn't logged in for a day gets a clean slate; an active user keeps their existing rows.

New endpoints

GET `/api/v1/sessions`

Auth: JWT (user role)

Returns: [

```
{
  sid: <uuid>,
  created_at: <unix_seconds>,
  last_seen_at: <unix_seconds>,
  device_label: <string | null>,
  via_recovery: <boolean>,
  is_current: <boolean>,
},
...
]
```

Sorted by `last_seen_at` descending. `is_current` is true for the row matching the calling JWT's sid. Empty array is a valid response (e.g., session pruned between calls).

DELETE `/api/v1/sessions/:sid`

Auth: JWT (user role)

Returns: 204 No Content on success.

Errors: 401 (no JWT or stale sid), 404 (sid not found OR belongs to a different account – no existence leak across accounts).

DELETE `/api/v1/sessions`

Auth: JWT (user role)

Query: `?except=current` – optional; preserve the calling sid.

Returns: 204 No Content. Without `?except=current`, the calling JWT's sid is also deleted; the next request from this client will 401.

All three endpoints scope by `data_lookup_key` extracted from the JWT. A user cannot list, see, or revoke sessions belonging to another account.

Auth middleware: stateful verification

User-role JWTs with a `sid` claim now require an additional D1 check:

1. Verify JWT signature + exp (existing)
2. Extract sid from claims; if absent (pre-7.5 JWT), grandfather — see migration
3. Look up sid in sessions table (with isolate-level cache, see below)
4. If row absent → 401
5. Update last_seen_at via `ctx.waitUntil()` (off the hot path, throttled — skip if existing last_seen_at is < 60s old)

Isolate-level cache

The naïve implementation runs a D1 SELECT on every authenticated request. To amortize: each Worker isolate keeps a small `Map<sid, { active: boolean, cachedAt: number }>` with a 5-second TTL.

- **Hit (within TTL):** answer from memory; no D1 read.
- **Miss or stale:** D1 SELECT, update cache.
- **Revoke endpoints:** the isolate handling the revoke updates its own cache entry to `active: false` immediately; other isolates serve stale until the 5-second TTL expires.

Net revocation latency: ≤5 seconds globally, immediate on the originating isolate. The 5-second window is acceptable — the threat model already accommodates same-origin-XSS-equivalent risk for the lifetime of the JWT (15 min). A 5-second cross-isolate inconsistency is well within that envelope.

The cache is in-memory only; no KV, no Durable Object. It evaporates on isolate eviction (no persistence concern) and is naturally bounded by the working set of recent sids.

Pre-7.5 migration

Rolling deploy:

1. Apply the D1 migration creating the `sessions` table.
2. Deploy the Worker. From this moment, new JWTs from `/auth/verify` carry `sid` and create rows. Existing in-flight JWTs (no `sid` claim) are grandfathered — the auth middleware skips the sessions check when the claim is absent.
3. After ~15 minutes (the JWT TTL), all live JWTs carry `sid` and the grandfather path is dead code. It is left in place for safety (handles a clock skew or a long-lived test JWT); it's a no-op for production traffic.

No client-side migration is required. SDKs older than 7.5 continue to work — they receive sid-bearing JWTs from the new server but don't pass `previous_sid` on re-verify, so each refresh creates a new row. That's the "table bloat" path; the lazy-prune step keeps it bounded. SDK upgrade brings the client onto the continuity path.

Interaction with credential rotation

`changeCredentials`, `recoverAccount`, and `deleteAccount` all rotate the signing key. The new `public_key` invalidates old JWTs at signature-check time, so revoking sessions is technically redundant — but doing it explicitly is the cleaner mental model and removes any timing-window concern.

The API performs:

```
DELETE FROM sessions WHERE data_lookup_key = ?1
```

as part of each operation, before publishing the new credential blob. The SDK additionally calls `clearSession()` (Section 7) on the local device to wipe the persisted blob.

SDK API surface

```
client.listSessions(): Promise<Array<SessionInfo>>
  SessionInfo = {
    sid, createdAt, lastSeenAt, deviceLabel, viaRecovery, isCurrent
  }
  Auth: requires authenticated client. Returns sessions for the calling user.
```

```
client.revokeSession(sid: string): Promise<void>
  Auth: requires authenticated client. 404 surfaces as null (caller can no-op
  or refresh listSessions to reflect the now-removed row).
```

```
client.revokeAllSessions(): Promise<void>
  Revokes all sessions including the current. After this resolves, the SDK
  also calls clearSession() locally; the caller should treat the client as
  dead and prompt for re-login.
```

```
client.revokeOtherSessions(): Promise<void>
  Revokes all sessions except the current. Implemented by the SDK as a
  DELETE /api/v1/sessions?except=current. Current session continues working.
```

Plus optional `deviceLabel` parameters on the existing entry points:

```
client.register(email, password, { ..., deviceLabel?: string })
client.login(email, password, { deviceLabel?: string })
client.recoverAccount({ ..., deviceLabel?: string })
```

`deviceLabel` flows to `/auth/verify` and is stored on the freshly-created session row. It is not modifiable post-creation in v1; a future endpoint may add `PATCH /api/v1/sessions/:sid` for relabeling.

Known v1 gaps

- **24h pruning window.** The lazy-prune step deletes sessions older than 24h, so a user who logs in once and never returns has no surfacing in `listSessions` even if their JWT is still valid (it isn't — JWT TTL is 15 min). For long-term audit logging, a separate "session-history Arweave-pinned audit log" would be a different piece of work; not v1.
- **Revocation latency up to 5 seconds.** Bounded by the isolate cache TTL. Acceptable trade-off for amortized D1 reads. If a use case demands sub-second revocation, the cache

TTL can be lowered or disabled per-environment via a config.

- **No device-grouping heuristics.** The SDK's `previous_sid` continuity keeps it to one row per device-installation, but a single user with two browser profiles on the same physical machine has two rows. Apps that want to group by physical device must rely on app-supplied `device_label` to disambiguate.
- **App-role JWTs are stateless.** Per-app session tracking would require a separate `app_sessions` table and is out of scope for 7.5.

Invite tokens (Section 8, issue #22)

The connection-handshake primitives shipped under Sections 5a–5d let two users form an end-to-end-encrypted connection if and only if the sender already knows the recipient's email and the recipient is a Tarn user with `share_discoverable=true`. For a large class of consumer-app flows — "scan this QR to add me", "send this link to your friend in Slack", "register and click my invite link" — those preconditions don't hold. Section 8 adds a complementary primitive: **opaque, single-use, time-limited invite tokens** that let the inviter publish a redemption slot without knowing the recipient's identity, and let the recipient redeem it (potentially after signing up) without ever transmitting the inviter's identifier through the channel that carried the link.

Why server-mediated

Three alternative shapes were considered and ruled out:

1. **Stateless QR / link** — keys baked into the URL, no server state. Loses single-use; a leaked link in any messenger channel exposes the inviter to arbitrary stranger redemption forever.
2. **Pure-Arweave invite blob** — inviter publishes an Arweave entry; recipient reads it, sends a normal connection request. Single-use cannot be enforced at storage (Arweave is immutable); app-side single-use ("accept the first matching request, drop the rest") races between the legitimate recipient and any malicious party that scrapes the link.
3. **Reuse the existing inbox-tag mechanism** — the inbox is `share_pub`-keyed and time-windowed; an "anonymous inbox" without a `share_pub` doesn't fit the model, and we'd be inventing single-use semantics on a primitive that doesn't want them.

All three lose the atomic single-use property that only the server can provide cheaply. Section 8 is server-mediated for that reason and that reason alone — every other piece of the flow is client-side cryptography over an opaque blob.

Cryptographic shape

The inviter generates two independent 32-byte secrets client-side:

- `token_id` — opaque server-side index. 256-bit URL-safe random. Sent to the API in the path; the server stores ciphertext keyed on it.
- `payload_key` — AES-256-GCM key that encrypts the invite payload. **Never transmitted to the API.** Carried only in the URL fragment, which browsers do not include in HTTP requests.

```

plaintext = JSON({
  inviter_share_pub:    <base64url 32 bytes>,
  inviter_signing_pub:  <base64url SPKI>,
  inviter_display_name: <string ≤ 64 chars>,
  app_id:               <string>,
  issued_at:            <unix seconds>
})
ciphertext = IV(12) || AES-256-GCM(plaintext, payload_key, IV) + tag
on-wire     = base64(ciphertext)           # what `payload` field carries
url         = <apps.invite_url_template, with {token_id}> # base64url(payload_key) in
               the URL fragment

                                   # see "App-side URL template"

below

```

The server stores `(token_id, payload, ...metadata)` and never learns the contents of `payload` — `inviter_share_pub`, `inviter_signing_pub`, and `inviter_display_name` are not visible to the API. This is the consistent zero-knowledge story across the rest of the protocol.

App-side URL template

There is no Tarn-hosted landing page. Apps own the URL surface. A new column on the `apps` table records each app's invite URL template:

```

ALTER TABLE apps ADD COLUMN invite_url_template TEXT;
-- e.g. "https://app.bookish.example/invite/{token_id}"
-- {token_id} is the only supported substitution.

```

Set at app onboarding. The SDK calls `GET /api/v1/apps/:app_id/invite-template` (or returns it from `createInviteToken` directly) and constructs the final URL by substituting `{token_id}` and appending `#<base64url(payload_key)>` as the fragment.

The app's web handler at that URL is responsible for:

- Reading `token_id` from the path and `payload_key` from `window.location.hash.slice(1)`.
- Calling `tarn.previewInviteToken(token_id, payloadKey)` to populate any "Maya invited you" UI it wants.
- Calling `tarn.redeemInviteToken(token_id, payloadKey)` once the recipient is authenticated (signing up first if needed).
- Server-side rendering the page with `<meta property="og:title">` etc. for messenger-preview unfurls — the app can fetch the unauthenticated preview server-side to populate them.
- Universal Links / App Links handling for native apps.

Tarn's surface stays the protocol primitive plus a per-app URL template. The UX is the app's.

D1 schema

```
CREATE TABLE invites (
  token_id TEXT PRIMARY KEY,          -- 256-bit URL-safe random, client-generated
  app_id TEXT NOT NULL,
  inviter_dlk TEXT NOT NULL,          -- inviter's data_lookup_key
  payload BLOB NOT NULL,              -- opaque AES-GCM ciphertext
  issued_at INTEGER NOT NULL,         -- unix seconds
  expires_at INTEGER NOT NULL,        -- unix seconds; default issued_at + 7d, max 30d
  used_at INTEGER,                   -- NULL until redeemed
  redeemer_share_pub_fingerprint TEXT -- short hex; populated on redeem for sender
  display
);

CREATE INDEX idx_invites_expires ON invites(expires_at);
CREATE INDEX idx_invites_inviter ON invites(inviter_dlk);
```

`payload` is byte-stable for the inviter's session (the same `(plaintext, payload_key)` always wraps to the same ciphertext given a fixed IV; the IV is fresh per invite, so different invites have different bytes — this property doesn't matter to retry idempotency since `token_id` is the primary key).

Lazy cleanup (no cron)

Tarn has no cron infrastructure (`auth_nonces` and `write_rate_limits` both use lazy expiry; we follow the precedent):

- `previewInvite` and `redeemInvite` filter by `expires_at` in the SELECT — expired rows behave as 410 Gone regardless of physical presence.
- `redeemInvite` opportunistically issues `DELETE FROM invites WHERE expires_at < ?1` on ~5% of calls (the same probabilistic-cleanup pattern used by `write_rate_limits`).

The 24-hour grace before deletion documented in the original RFC is unnecessary under this model — expired-but-undeleted rows are filtered out by the SELECT side.

Endpoints

POST `/api/v1/invite` (authenticated, user-role)

Body: { `token_id`, `app_id`, `payload`, `expires_at` }

- `token_id`: 43-char base64url
- `payload`: base64 of IV || ciphertext+tag (max 4 KiB on the wire)
- `expires_at`: unix seconds; server enforces $\leq \text{now} + 30 \text{ days}$
- `app_id` must equal the JWT's app claim

Returns 201: { `token_id`, `expires_at` }

Errors:

- 400 if `expires_at` > 30d in the future, or `token_id` malformed
- 409 if `token_id` already exists (caller retries with fresh random)
- 413 if `payload` > 4 KiB
- 429 if inviter has exceeded the rate limit (see below)

GET /api/v1/invite/:token_id (unauthenticated)

Returns 200: { app_id, payload, issued_at, expires_at }
payload is the opaque ciphertext (base64). Recipient decrypts client-side.

Errors:

- 404 if not found
- 410 if expired
- 409 if already used (used_at IS NOT NULL)
- 429 if per-IP preview rate exceeded

The app_id and timestamps are unencrypted — they're already implied by the URL hosting the invite, and the recipient's app needs app_id to confirm scope before redeeming. Everything else (inviter_share_pub, signing_pub, display_name) is inside the encrypted payload.

POST /api/v1/invite/redeem/:token_id (authenticated, user-role)

Body: { redeemer_share_pub_fingerprint }
- redeemer_share_pub_fingerprint: short hex (e.g., 8 chars) of the recipient's share_pub, recorded for the inviter's listIssuedInvites display.

Atomicity: UPDATE invites SET used_at = ?1, redeemer_share_pub_fingerprint = ?2
WHERE token_id = ?3 AND used_at IS NULL AND expires_at > ?4
If affected_rows = 0:
- Lookup the row to determine error mode
- 410 if expired, 409 if already used, 404 otherwise

Returns 200: { app_id, payload, issued_at, expires_at }
Same shape as preview; recipient decrypts and proceeds with the connection-request HPKE handshake.

Errors: 404 / 410 / 409 / 429 as above

The redemption response includes the same payload as preview because the server can't tell the difference — both responses serve opaque ciphertext. The server-side state change is used_at being set atomically.

Rate limiting

Existing primitives, no new infrastructure:

- **Create** — checkWriteRateLimit -style D1 atomic counter, key invite-create:<dlk>:<hour> , max **10/hour per inviter**. Atomic via INSERT ... ON CONFLICT DO UPDATE .
- **Redeem** — same shape, key invite-redeem:<dlk>:<hour> , max **50/hour per redeemer**. Bounded to detect runaway redemption clients.
- **Preview** — checkAndIncrementRateLimit (KV), key invite-preview:<ip-hash>:<hour> , max **100/hour per IP**. Defense-in-depth against token-id enumeration; the 256-bit token space already makes brute-force infeasible.

All three fail open on rate-store outage (consistent with existing patterns).

Connection.label primitive

The current connections record stores `share_pub` , `signing_pub` , `email` , `established_at` , `initial_request_nonce` . The `listConnections` JSDoc (<client/src/tarn.js>) lists `label?: string` as an optional field, but no code reads or writes it — vestigial.

Section 8 makes it a first-class primitive:

- `acceptConnectionRequest(nonce, { label })` — optional label set at accept time.
- `setConnectionLabel(connection, label)` — relabel an existing connection.
- `listConnections()` returns `label` per entry (always present in the type, may be `null`).
- The label persists in the connections record (`tarn-connections-v1`) blob alongside other per-connection fields. No new server-side surface.
- The label is local to the labeling user — the labeled party does not see what they were labeled.

Used by invite redemption to seed the connection's label with the inviter's `display_name` from the decrypted payload, so apps get an out-of-the-box "this is Maya" without app-layer storage.

Auto-accept on the inviter side

After the recipient redeems and sends a normal connection request back, the inviter's app sees an inbound request with a new optional field, `via_invite_token: <token_id>` . The SDK's `listIncomingRequests` surfaces this; the SDK's auto-accept logic on the inviter side:

1. Receives the inbound request.
2. **Reads** `tarn-issued-invites-v1` **fresh from the API** (no in-memory cache — the issuer may have created the invite on a different device, and that device's write hits D1 synchronously, but the receiving device's in-memory state can be stale).
3. If `via_invite_token` matches an entry in `tarn-issued-invites-v1` , auto-accepts (no UI prompt).
4. If no match, the request stays in the pending list as a normal incoming request — the user sees it and decides. (Not silently dropped; that would lose legitimate redemptions during edge-case scenarios.)

The `tarn-issued-invites-v1` blob is the standard encrypted-data-blob pattern (mirrors `tarn-muted-connections-v1` , `tarn-connections-v1` , etc.):

```
content_id = "tarn-issued-invites-v1"
plaintext = JSON({
  app_id: <string>,
  version: 1,
  invites: [
    {
      token_id, display_name, issued_at, expires_at,
      redeemed_at, redeemer_share_pub_fingerprint
    },
    ...
  ]
})
```

})

DEK-encrypted. Synced across the inviter's devices via standard data-blob storage. Pruned locally once the matching connection is established or the entry expires.

Threat model

- **Leaked invite link** (screenshot, accidental Slack post). Mitigations: 7-day default expiry, hard 30-day max, single-use, sender-visible `redeemer_share_pub_fingerprint` so inviter can detect surprise redemption and revoke + reissue.
- **Malicious recipient redeems but refuses the handshake**. Token consumed; inviter must reissue. No worse than the email-flow case where a recipient declines.
- **Server compromise**. Attacker can enumerate live tokens via the `invites` table but cannot decrypt payloads (the `payload_key` lives only in URL fragments held by recipients). Best they can do is mark tokens used (denial-of-service) or redirect connection-request handshakes (which fail signature verification on the inviter side because the attacker doesn't have the recipient's identity to sign as).
- **Token enumeration**. 256-bit space is brute-force-infeasible regardless. The 100/hour/IP preview rate-limit is defense-in-depth.
- **Inviter-identity exposure to API operators**. Operators see `(inviter_dlk, token_id, time, redeemer_fingerprint)` per row. They do **not** see `inviter_share_pub`, `inviter_signing_pub`, or `inviter_display_name` — those are inside the encrypted payload.

SDK surface

```
client.createInviteToken({
  display_name?: string,           // shown to recipient at preview/redeem time, ≤ 64 chars
  expiry_days?: number,           // default 7, server max 30
}): Promise<{
  token_id: string,
  invite_url: string,             // app's template + #fragment, ready to share
  expires_at: number,
}>

client.previewInviteToken(token_id, payloadKey): Promise<{
  inviter_display_name: string,
  inviter_share_pub_fingerprint: string, // short hex for verification UI
  app_id: string,
  issued_at: number,
  expires_at: number,
} | null> // null on expired / used / not found

client.redeemInviteToken(token_id, payloadKey): Promise<Connection>
// Throws on expired / used / not found / app_id
  mismatch.
// The returned connection becomes live once the
  inviter's
// session auto-accepts the inbound request.

client.listIssuedInvites(): Promise<Array<IssuedInvite>>

client.revokeIssuedInvite(token_id): Promise<void>
// App-side delete from tarn-issued-invites-v1, plus a
// best-effort DELETE /api/v1/invite/:token_id on the
  server.

client.acceptConnectionRequest(nonce, { label? }): Promise<Connection> // updated
client.setConnectionLabel(connection, label): Promise<void>           // new

listConnections return type gains label: string | null .
```

Known v1 gaps

- **No multi-redeem variant.** All v1 invites are single-use. A `max_redemptions: N` flag for "invite link to a book club" use cases is plausible follow-up but has a different threat model and is deferred.
- **No revocation propagation.** `revokeIssuedInvite` clears the inviter's local record and best-effort deletes from the server. A malicious recipient who already retrieved (but not yet redeemed) the payload via preview can still attempt redemption; the server-side delete prevents it from succeeding. Acceptable.
- **No anonymous-inbox-style metadata privacy.** Server learns `(inviter_dlk, time)` for every issued invite and `(token_id, redemption_time, IP)` for every redemption. Acceptable disclosure given the tight binding to the inviter's account; documented in [Publicly observable metadata](#) below.

- **App-onboarding.** Setting `invite_url_template` is part of the existing manual app-registration flow; no developer-portal self-service in v1.

Publicly observable metadata

Tarn protects content (and the keys protecting content) end-to-end, but a number of metadata properties are observable to anyone who knows enough to ask. Apps building on Tarn should be aware of what's visible vs. what's protected, and surface this honestly to users where relevant.

What's protected (encrypted; not observable to anyone without keys):

- All content blobs (book entries, etc.) — encrypted under per-content CEKs, only owner + explicitly-shared recipients can decrypt.
- All share-log entries (per-pair shared content) — encrypted under per-pair `K_AB`.
- All connection-handshake payloads (request + accept) — HPKE-sealed to recipient's `share_pub`.
- All friend-graph relationships — neither Tarn nor an Arweave observer can extract who is connected to whom from the protocol alone.
- All recovery phrases — generated client-side, never persisted by Tarn.

What's publicly observable (no keys needed):

- **Connection-request inbox metadata.** `GET /api/v1/share/inbox/fetch` is **unauthenticated by design** — a recipient who lost their JWT (e.g., still booting on a fresh device) needs to be able to poll their inbox. Anyone who knows a user's `share_pub` can:

- Compute their inbox tag for any time window (the tag is `HMAC(H(share_pub), "tarn-connection-inbox-v1-" || app_id || "-" || window)` — derivable from public info)
- Fetch the sealed-but-non-decryptable HPKE blobs at that tag
- Observe the **volume + timing** of incoming connection requests for that user

The contents stay encrypted; only HPKE recipient (the user) can open them. But "user X received N connection requests on day D" is publicly extractable.

- **Account existence via discoverability.** If a user has `share_discoverable=true`, anyone who knows their email can look up their `share_pub` via `GET /api/v1/share/lookup`. This confirms the email is a registered Tarn user. If `share_discoverable=false`, the lookup returns `share_pub: null` — but existing connections already cached `share_pub` from the original handshake.

- **Per-recipient activity from share-log writes.** Tarn's per-tag uniqueness check at `POST /api/v1/share/log/publish` means an observer querying tag-existence can confirm specific tags are taken. Tags are pseudorandom (HMAC under per-pair secret), so this doesn't reveal relationships, but bulk-enumeration of common patterns isn't ruled out at scale.

- **Aggregate volume + timing on Arweave.** All Tarn-bundled writes are signed by the Tarn-bundler wallet on Arweave. An Arweave observer can see "Tarn bundler activity per hour" but cannot link writes to individual users without protocol-level knowledge.

Acceptable residual leaks documented for v1 (per sharing design §11.5):

1. **Email-based discoverability lookup leaks "user A is interested in user B"** at handshake time. Once connected, all subsequent traffic is unlinkable — the per-pair tags are stealth-addressed.
2. **Tarn-side correlation** of write/read timing per session may allow Tarn (the operator) to infer some relationships statistically. Mitigation deferred (would require dummy traffic, mixing networks, etc.).
3. **Per-recipient inbox metadata** (the bullet above) — accepted because the unauthenticated fetch is a hard requirement for fresh-device recovery flows.

App-side guidance:

Apps building on Tarn should communicate in user-facing privacy docs that:

- Connection-request **timing and volume** can be observed by anyone who has seen the user's `share_pub` (typically: their email contacts + accepted connections).
- Setting `share_discoverable=false` prevents new strangers from discovering the user's `share_pub` via email lookup, but does not retroactively hide it from anyone who already cached it.
- **Content** is protected by end-to-end encryption; only the people the user explicitly shares with can read what they share.

For most use cases (private reading lists, friend-circle apps), these properties are appropriate trade-offs. For higher-stakes sensitive data, additional mitigations (decoy traffic, alternative discovery flows) would be needed; sharing roadmap §14.2 + §14.7 covers that direction.

Cryptographic References

- **HKDF:** RFC 5869 — HMAC-based Extract-and-Expand Key Derivation Function
- **AES-KW:** RFC 3394 — Advanced Encryption Standard Key Wrap Algorithm
- **PBKDF2:** RFC 8018 — Password-Based Key Derivation Function 2
- **AES-GCM:** NIST SP 800-38D — Galois/Counter Mode
- **ECDSA P-256:** FIPS 186-4 — Digital Signature Standard
- **Pattern:** Bitwarden-style architecture (PBKDF2 → master key → sub-keys → wrapped data key) with LUKS-style key slot wrapping

Open Questions

1. **Protocol versioning:** The `v` tag and the `version` field in the HKDF info string allow future derivation changes (e.g., PBKDF2 → Argon2id). Migration path needs design.
2. **Rate limiting on registration:** Registration is unauthenticated. IP rate limiting sufficient for now. CAPTCHA or proof-of-work at scale.
3. **Multiple credential mappings after changes:** Old credential mappings persist on Arweave. On rebuild, latest wins. Minor information leak (credential change history via shared `data_lookup_key`).
4. **App wallet monitoring:** Turbo balance monitoring and top-up. Operational concern, not protocol.